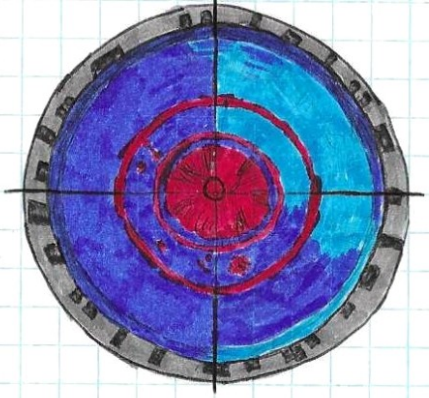


Evaluation des Vulnérabilités:

Catégorie : Offensif
Difficulté : Easy . Cur 0
Durée estimé : 2 Heures

Les types d'evaluation de sécurité:

Une evaluation de sécurité à pour but de confirmer et trouver la présence de vulnérabilité (physique) + numériques au sein d'une entité. Ce n'est pas un teste d'Intrusion, les evaluations de sécurité à l'inverse ne simulent pas de cyberattaques. Toute les entreprises doivent en effectuer de temps à autres, ces evaluations passe par une liste de control : (Ex Respectons nous cet norme? avons nous cette config?) En gros une evaluations de sécurité n'est pas un pentest, mais un pentest est une forme d'evaluation de sécurité.
Il existe d'autres types d'evaluation de la sécurité :
[+] Audit de Sécurité : généralement des exigences provenant de l'exterieur de l'organisation par exemple les fournisseurs de services de paiment.
[+] Programmes de Bug Bounty : L'entreprise definit un scope et ouvre l'audit au grand public avec des primes à la faille.
[+] Equipes rouges / violette : demande un important budget, equipes de professionnels de la sécurité qui simule une cyberattaque de niveau avancé voir APT afin de renforcé la sécurité de l'entreprise, ils sont en communication avec les équipes Blue Team on parle de purple team

Quelques definitions avant de detailler la methodologie de l'evaluation de vulnérabilités:

- Risques : quelque chose de mal qui pourrait arriver
- Menace : quelque chose de mal qui est entrain d'arriver
- Vulnérabilités : faiblesses qui pourraient mener à une menace
- Actifs de donnée : Lorsque une organisation planifie sa sécurité elle doit commencer par créer un inventaire de ses actifs de données, si on veux protiger quelque chose on doit savoir exactement quoi.

La Methodologie 8 étapes:

1- Identification et analyse des risques : identifier les technologies et tout les équipements du system informatiques de l'entreprise ainsi que les risques associés

2- Developper la politique du scan de vulnérabilités : cette politique doit etre écrite avoir un responsable officiel, et l'accord de la direction

3- Identifier le type de scan : depend des logiciels tournant sur la cible, l'objectif est de scanner sans abimer et en sécurisant les types de scan incluent, réseau, basé sur les hotes, sur le sans-fil, sur les applications...

4- Configurer le scan : ajouter les listes d'IP, definir les plages les ports et protocoles des cibles, mais aussi l'agressivité du scan, sa durée, et les notifications

→